

CYBERSECURITY

LAB 1

1. Introduction

Penetration testers are faced with a combination of firewalls, intrusion detection systems, host-based protection, hardened systems, and teams of knowledgeable analysts that pour over data collected by their security information management systems. In an environment such as this, simply running automated tools will typically yield few results. The false sense of this security can easily result in the loss of critical data and resources.

Advanced Penetration Testing for Highly Secured Environments provides guidance on going beyond the basic automated scan. It will provide you with a stepping stone which can be used to take on the complex and daunting task of effectively measuring the entire attack surface of a traditionally secured environment.

The first part is dedicated to some security problems related to modern and historical cryptography. In this part you will have to perform some experiments using CrypTool application to get familiar with strength, weakness and traps of cryptographic algorithms. You will learn about the most important directions in modern cryptography and you will find out some basic rules how to select the most appropriate algorithms and use how to use them. Having the knowledge from this part you will be able to provide confidentiality and verify integrity of your data. You will also get to know how to authenticate the source of information.

2. Agenda

- Lab1 - Intro
- Lab2 - Early crypto
- Lab3 - Stream and block ciphers
- Lab4 - Asymmetric ciphers
- Lab5 - Attacks on modern ciphers
- Lab6 - Crypto hash functions
- Lab7 - Applications of modern crypto
- Lab8 - Network security problems
- Lab9 - Secure network transmission
- Lab10 - OSINT
- Lab11 - Network reconnaissance
- Lab12 - Exploitation
- Lab13 - WEB security 1
- Lab14 - WEB security 2
- Lab15 - Revision

INTRODUCTION

3. Lab Rules & Regulations

For each lab student should be prepared. It means student should read the instruction first and learn about the elements enumerated in the section 'prerequisites'.

During the lab students perform steps described in the instruction and record the results in the lab report. The report should also contain the answers to the questions and/or the solutions of the problems.

After the lab the students must upload their reports to the WUT e-learning portal.

During the next lab students should be prepared to answer the questions related to the work done and their reports.

Each student should:

1. Follow current announcements and guidelines available on portal <http://eportal.pwr.wroc.pl/>
2. General procedure
 - a. Download the lab instruction
 - b. Learn what is needed to perform successfully the lab (what you should know, what tools you should use, etc.)
 - c. Perform the steps listed in the instruction
 - d. After the experiments prepare the document including:
 - brief characteristic of performed steps and their results
 - summary and answer to the questions included in the lab instruction
 - e. Upload your document to the portal <http://eportal.pwr.wroc.pl/>
 - f. Each your report will be evaluated.
 - g. Your grade is related to the quality of the report and the timeliness.
 - h. Be prepared to answer to the teacher's questions

3. Tools you will need

a. CrypTool 1

The application CrypTool is a free e-learning application for Windows. You can use it to apply and analyze cryptographic algorithms. The current version of CrypTool ([Download](#)) is used all over the world. It supports both contemporary teaching methods at schools and universities as well as awareness training for employees and civil servants.

The current version offers [beside others](#) the following highlights:

- Numerous classic and modern cryptographic algorithms (encryption and decryption, key generation, secure passwords, authentication, secure protocols, ...)
- Visualisation of several methods (e.g. Caesar, Enigma, RSA, Diffie-Hellman, digital signatures, AES)
- Cryptanalysis of certain algorithms (e.g. Vigenère, RSA, AES)
- Crypt-analytical measuring methods (e.g. entropy, n-grams, autocorrelation)
- Auxiliary methods (e.g. primality tests, factorisation, base64 coding)
- Tutorial about number theory
- Comprehensive online help
- Supportive script with further information about cryptology

INTRODUCTION

b. VirtualBox

Download and install up-to-date version of [Oracle VirtualBox](#) or any other virtualisation platform which will allow you to run tools required during labs (cryptool, kali linux, etc.). Currently supported version is 6.1.38 (it should be used for labs).

c. Kali Linux

During labs the we will mostly use security tools included in [Kali Linux](#). [Kali Linux \(Kali\)](#) is a Linux distribution system that was developed with a focus on the penetration testing task. Previously, Kali Linux was known as **BackTrack**.

Kali Linux contains a number of tools that can be used during the penetration testing process. The penetration testing tools included in Kali Linux can be categorized into the following categories:

- **Information gathering:** This category contains several tools that can be used to gather information about DNS, IDS/IPS, network scanning, operating systems, routing, SSL, SMB, VPN, voice over IP, SNMP, e-mail addresses, and VPN.
- **Vulnerability assessment:** In this category, you can find tools to scan vulnerabilities in general. It also contains tools to assess the Cisco network, and tools to assess vulnerability in several database servers. This category also includes several fuzzing tools.
- **Web applications:** This category contains tools related to web applications such as the content management system scanner, database exploitation, web application fuzzers, web application proxies, web crawlers, and web vulnerability scanners.
- **Password attacks:** In this category, you will find several tools that can be used to perform password attacks, online or offline.
- **Exploitation tools:** This category contains tools that can be used to exploit the vulnerabilities found in the target environment. You can find exploitation tools for the network, Web, and database. There are also tools to perform social engineering attacks and find out about the exploit information.
- **Sniffing and spoofing:** Tools in this category can be used to sniff the network and web traffic. This category also includes network spoofing tools such as Ettercap and Yersinia.
- **Maintaining access:** Tools in this category will be able to help you maintain access to the target machine. You might need to get the highest privilege level in the machine before you can install tools in this category. Here, you can find tools for backdooring the operating system and web application. You can also find tools for tunneling.
- **Reporting tools:** In this category, you will find tools that help you document the penetration-testing process and results.
- **System services:** This category contains several services that can be useful during the penetration testing task, such as the Apache service, MySQL service, SSH service, and Metasploit service.

To ease the life of a penetration tester, Kali Linux has provided us with a category called **Top 10 Security Tools**. Based on its name, these are the top 10 security tools commonly used by penetration testers. The tools included in this category

INTRODUCTION

are aircrack-ng, burp-suite, hydra, john, metasploit, nmap, sqlmap, wireshark, and zaproxy.

Besides containing tools that can be used for the penetration testing task, Kali Linux also comes with several tools that you can use for the following:

- **Wireless attacks:** This category includes tools to attack Bluetooth, RFID/NFC, and wireless devices.
- **Reverse engineering:** This category contains tools that can be used to debug a program or disassemble an executable file.
- **Stress testing:** This category contains tools that can be used to help you in stress testing your network, wireless, Web, and VOIP environment.
- **Hardware hacking:** Tools in this category can be used if you want to work with Android and Arduino applications.
- **Forensics:** In this category, you will find several tools that can be used for digital forensics, such as acquiring a hard disk image, carving files, and analyzing the hard disk image. To use the forensics capabilities in Kali Linux properly, you need to navigate to **Kali Linux Forensics | No Drives or Swap Mount** in the booting menu. With this option, Kali Linux will not mount the drives automatically, so it will preserve the drives' integrity

d. Metasploitable

[Metasploitable 2](#) has many vulnerabilities in the operating system, network, and web application layers. Information about the vulnerabilities contained in Metasploitable 2 can be found on the [Rapid7 site](#).

There is also a newer version of the framework [Metasploitable 3](#).

e. pfSense

[pfSense](#) is a freely distributed and open source BSD operating system derived from the well known m0n0wall project, but with radically different goals like using Packet Filter and the latest FreeBSD technologies.

The project can be used as both router and firewall. It includes a package system that allows system administrators to easily extend the product without adding potential security vulnerabilities and bloat to the base distribution.

Key features include state-of-the-art firewall, inbound/outbound load balancing, state table, NAT (Network Address Translation), high availability, VPN (Virtual Private Network) with support for IPsec, PPTP and OpenVPN, PPPoE server, Dynamic DNS, captive portal, reporting, and monitoring.

It is an actively developed firewall operating system, distributed as gz archived Live CD and installation-only ISO images, USB stick installers, as well as NanoBSD/embedded media. Both 64-bit (amd64) and 32-bit (i386) hardware platforms are supported at this time.

Several predefined boot options are available during the boot process, such as to boot the operating system with default settings, with ACPI disabled, using USB devices, in safe mode, in single user mode, with verbose logging, as well as to access a shell prompt or reboot the machine.

f. Burp suite (community edition)

[Burp Suite](#) is an integrated platform for performing security testing of web applications. Its various tools work seamlessly together to support the entire testing process,

INTRODUCTION

from initial mapping and analysis of an application's attack surface, through to finding and exploiting security vulnerabilities.

Burp gives you full control, letting you combine advanced manual techniques with state-of-the-art automation, to make your work faster, more effective, and more fun.

g. Snort

A network intrusion detection and prevention system excels at traffic analysis and packet logging on IP networks. Through protocol analysis, content searching, and various pre-processors, Snort detects thousands of worms, vulnerability exploit attempts, port scans, and other suspicious behavior. Snort uses a flexible rule-based language to describe traffic that it should collect or pass, and a modular detection engine. Also check out the free [Basic Analysis and Security Engine \(BASE\)](#), a web interface for analyzing [Snort](#) alerts.

h. OWASP ZAP

[Zed Attack Proxy \(ZAP\)](#) is a free, open-source penetration testing tool being maintained under the umbrella of the Open Web Application Security Project (OWASP). ZAP is designed specifically for testing web applications and is both flexible and extensible.

At its core, ZAP is what is known as a “man-in-the-middle proxy.” It stands between the tester's browser and the web application so that it can intercept and inspect messages sent between browser and web application, modify the contents if needed, and then forward those packets on to the destination. It can be used as a stand-alone application, and as a daemon process.

i. Some other tools you might find useful

- [Network Security Toolkit \(NST 32\)](#)
- [Fedora Security Spin](#)
- [BackBox](#)
- [Parrot Security](#)
- [Talis OS](#)
- [Qubes OS](#)

4. Configuration of the VM environment

- I. Configure the VM in VirtualBox (Update vbox to the last version 7.0)
 - a. Define a new NAT Network (VirtualBox - Settings)

INTRODUCTION

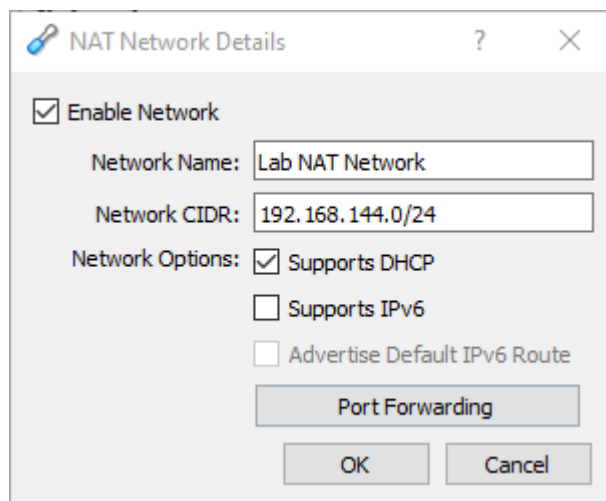
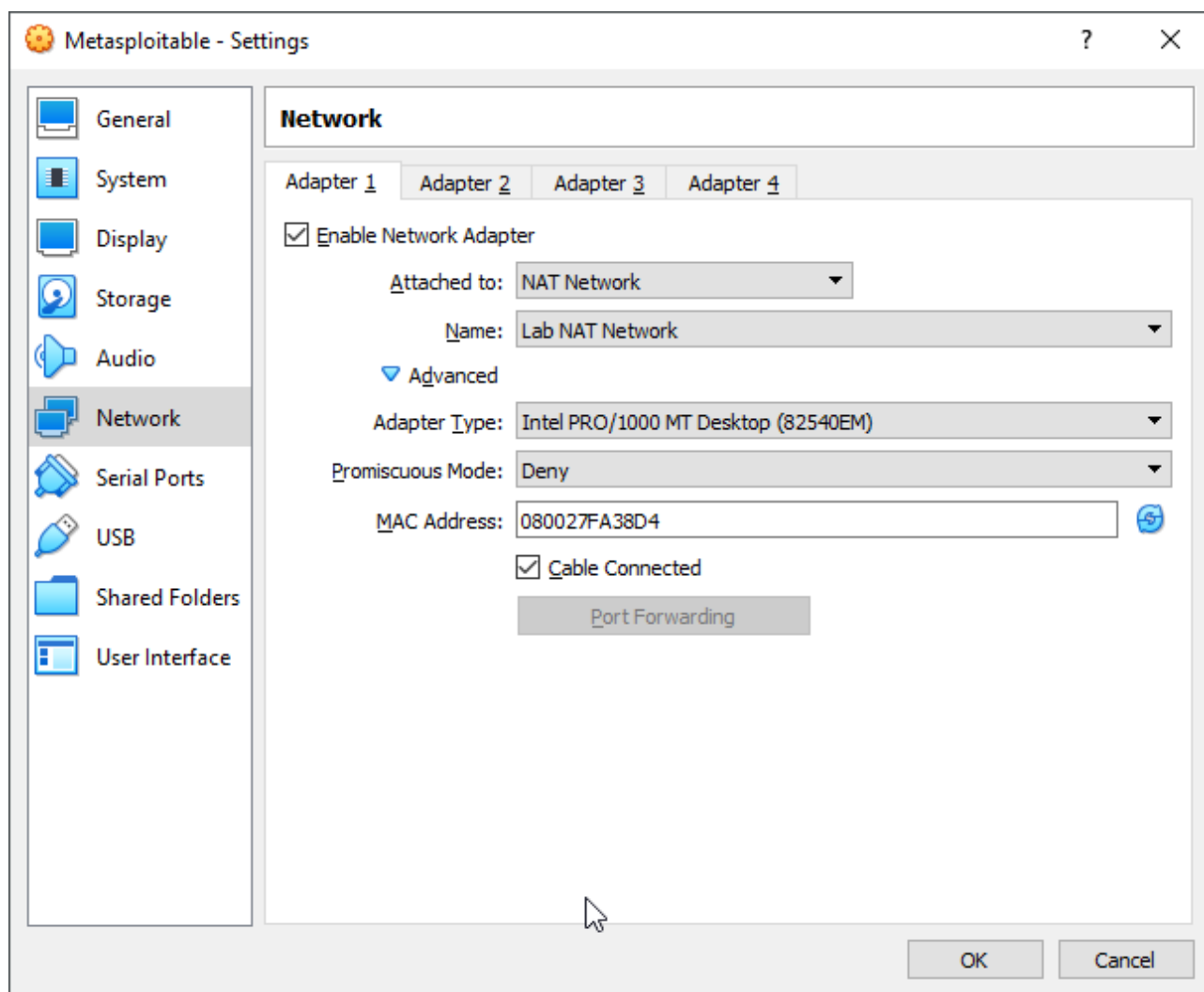


Fig. 1 Example NAT Network configuration

- b. Create VMs: Kali (installation), Metasploitable, others recommended by a teacher
- c. Configure VMs network interfaces (join them to previously created NAT Network)



- d. Run all machines with following credentials
 - i. Kali (stud,stud),

INTRODUCTION

- ii. Ubuntu Server (student, student)
- iii. Metasploitable (msfadmin, msfadmin)
- e. (Optional) If you want to use an SSH connection from the host to the virtual machine, you need to:
 - i. Open terminal
 - ii. Change current path to the VirtualBox installation path
 - iii. Use following command:
VBoxManage.exe guestproperty enumerate "VM_Name" (**change the name**)
 - iv. IP address can be found here:

```
$ VBoxManage.exe guestproperty enumerate "Kali Lab 2022/2023"
/VirtualBox/GuestAdd/HostVerLastChecked = '6.1.40' @ 2023-04-12T20:59:04.928Z
/VirtualBox/GuestAdd/Revision = '158379' @ 2024-01-17T07:45:46.914Z
/VirtualBox/GuestAdd/Version = '7.0.10' @ 2024-01-17T07:45:46.913Z
/VirtualBox/GuestAdd/VersionExt = '7.0.10' @ 2024-01-17T07:45:46.914Z
/VirtualBox/GuestInfo/Net/0/MAC = '080027BD917' @ 2024-01-17T07:45:51.950Z
/VirtualBox/GuestInfo/Net/0/Name = 'eth0' @ 2024-01-17T07:45:51.951Z
/VirtualBox/GuestInfo/Net/0/Status = 'Up' @ 2024-01-17T07:45:51.950Z
/VirtualBox/GuestInfo/Net/0/V4/Broadcast = '192.168.3.255' @ 2024-01-17T07:45:51.950Z
/VirtualBox/GuestInfo/Net/0/V4/IP = '192.168.0.19' @ 2024-01-17T07:45:51.950Z
/VirtualBox/GuestInfo/Net/0/V4/Netmask = '255.255.252.0' @ 2024-01-17T07:45:51.950Z
/VirtualBox/GuestInfo/Net/1/MAC = '0242D1ABA9D3' @ 2024-01-17T07:45:51.952Z
/VirtualBox/GuestInfo/Net/1/Name = 'docker0' @ 2024-01-17T07:45:51.952Z
/VirtualBox/GuestInfo/Net/1/Status = 'Up' @ 2024-01-17T07:45:51.952Z
/VirtualBox/GuestInfo/Net/1/V4/Broadcast = '172.17.255.255' @ 2024-01-17T07:45:51.951Z
/VirtualBox/GuestInfo/Net/1/V4/IP = '172.17.0.1' @ 2024-01-17T07:45:51.951Z
/VirtualBox/GuestInfo/Net/1/V4/Netmask = '255.255.0.0' @ 2024-01-17T07:45:51.952Z
/VirtualBox/GuestInfo/Net/Count = '2' @ 2024-01-17T07:46:06.961Z
/VirtualBox/GuestInfo/OS/Product = 'Linux' @ 2024-01-17T07:45:46.903Z
/VirtualBox/GuestInfo/OS/Release = '5.18.0-kali5-amd64' @ 2024-01-17T07:45:46.911Z
/VirtualBox/GuestInfo/OS/ServicePack = '' @ 2024-01-17T07:45:46.913Z
/VirtualBox/GuestInfo/OS/Version = '#1 SMP PREEMPT_DYNAMIC Debian 5.18.5-kali6 (2022-07-07)' @ 2024-01-17T07:45:46.912Z
/VirtualBox/HostInfo/GUI/LanguageID = 'pl_PL' @ 2024-01-17T07:46:10.413Z RDONLYGUEST
```

- f. Update Kali packages
 - i. apt-get update
 - ii. apt-get upgrade
- g. Check VMs IP addresses (ifconfig) and verify systems connectivity (ping)
- h. Configure shared folders
 - i. During a penetration testing process, we may find that we need to share files between the host OS and the guest OS, such as to store penetration testing results on the host machine. One of the mechanisms that can be used for this requirement is to use VirtualBox's **Shared Folders**
- i. HTTP
 - i. To start the Apache HTTP service type the following command to start the Apache server:
service apache2 start
 - ii. If there are no errors, the system will reply with the following message: [...] Starting web server: apache2 ok
 - iii. To stop the Apache HTTP service, perform the following steps: from the command line, type the following command to start the Apache server: **service apache2 stop**
 - iv. If there are no errors, the system will reply with the following message:
[....] Stopping web server: apache2 [ok waiting .

INTRODUCTION

- v. Remember that the previous command will not survive the boot up. After the boot up, you need to give the command again. Fortunately, there is a way to start the Apache HTTP service automatically after the Kali Linux boots up by giving the following command:

update-rc.d apache2 defaults

- vi. The command will add the apache2 service to be started on boot up.

j. MySQL

- i. from the command line, type the following:

service mysql start

- ii. Then, the system will respond with the following message:

[ok] Starting MySQL database server: mysqld . . .

[info] Checking for tables which need an upgrade, are corrupt or were not closed cleanly..

- iii. To test whether your MySQL has already started, you can use the MySQL client to connect to the server. We define the username (root) and the password to log in to the MySQL server:

mysql -u root -p

- iv. The system will respond with the following:

Enter password:

Welcome to the MySQL monitor. Commands end with ; or \g.

Your MySQL connection id is 42

Server version: 5.5.30-1 (Debian)

After this MySQL prompt, you can give any SQL commands. To exit from MySQL, just type quit.

- v. To stop the MySQL service, you can perform the following steps:

In the graphical menu, navigate to **Kali Linux | System Services | MySQL | mysql stop**; or, from the command line, type the following:

service mysql stop

- vi. Then, the system will respond with the following message:

[ok] Stopping MySQL database server: mysqld.

- vii. To start the MySQL service automatically after Kali Linux's boots up, you can give the following command:

update-rc.d mysql defaults

This command will make the MySQL service start after the boot up.

k. SSH

- i. type the following:

service ssh start

INTRODUCTION

- ii. The system will then respond with the following message:
[ok] Starting OpenBSD Secure Shell server: sshd.
- iii. To stop the SSHD service from the graphical menu, from the command line, type the following:
service ssh stop
- iv. The system will then respond with the following message:
[ok] Stopping OpenBSD Secure Shell server: sshd.
- v. To start the SSH service automatically after Kali Linux boots up, you can give the following command:
update-rc.d ssh defaults

This command will add the SSH service to be started on boot up.

5. Problems and questions

- a. What is the aim and the scope of the penetration testing?
- b. What is the difference between penetration testing and vulnerability assessment?
- c. What is “ethical hacking”?
- d. What are the basic types of penetration testing?
- e. Describe briefly some penetration testing methodologies (OSSTMM, ISSAF, OWASP, WASC-TC, PTES)